2. 資産のセキュリティ

2-1. 情報と資産を特定し、分類する

- 資産管理のライフサイクルでは、まず資産とは何かを明確に定義することから始める必要がある
- 目標と目的を達成するために3種類のリソースに依存
    - 材料
        - 部品
        - 部品杭縦品
        - ソフトウェア
        - データ
    - 消耗品
        - 燃料
        - 消耗部品
        - 梱包
    - 資産
        - 人
        - プロセスノウハウ
        - 施設
        - 機器
        - 保持された知識
    - 成果物
        - 製品
        - サービス

分類とカテゴリー化

- セキュリティラベリング
- 組織や国によって、分類は差異がある（似た概念でも異なる命名）
    - 軍事・国家安全保障コミュニティ
        - 情報の機密性を重視したセキュリティラベル
            - 秘密（Secret）
            - 最高機密（Top Sercret）
            - 公式使用のみ（For Official Use Only） など
        - 他の国および地域の政府のポリシー
            - 個人の健康情報
            - 営業秘密
            - 専有
- 長年にわたって、CIAトライアドの3属性のみに焦点が合わせられてきた （機密性（Confidentiality）：アクセス権が保たれていること/完全性（Integrity）：改竄されていないこと/可用性（Availability）：必要な時に利用できること）
    - 安全性・プライバシー・真正性・否認防止といった重要なセキュリティニーズを軽視したり無視したりする結果をもたらした
- 情報資産、またはそれに含めれるデータセットやデータ項目のCRUDに注意を払う必要あり
    - Creating：作成

    - Reading：読み取り
    - Updating：更新
    - Deleting：削除
- 分類
    - 機密性、完全性、可溶性、否認防止、真正性、プライバシー、または安全性に関する特性に関してセキュリティ上の侵害が発生した場合に、組織に及ぼす影響を認識するプロセス
- カテゴリー化
    - 同等の機微性（影響や損失の格付け）を持ち、法律、契約、またはその他のコンプライアンス体制で義務付けられた同様のセキュリティニーズを持つデータ、情報、または知識のセットをグループ化するプロセス

分類とカテゴリー化の利点

- 分類とカテゴリー化による利点の享受
    - 従業員と顧客の間での、組織の情報保護への取り組みの認識
    - 重要かつ機微な情報の特定
    - 変更に対する脆弱性の特定
    - 完全性コントロールの重点化
    - 貴重な情報を保護する必要性に対する感度
    - 情報の価値の理解
    - 法的要件への整合

分類およびカテゴリー化に関する課題

- 資産のオーナーは場合によっては、資産のカテゴリー化または分類の**責任**（＝タスクを達成するためのデューケアの義務）を委任できる
- ただし、委任しても資産オーナーはルネに資産の価値を保護する責任を負い続ける
- **アカウンタビリティ（説明責任）**は委任することができないため
- エラー
    - ヒューマンエラー
        - セキュリティにおける人的要素は最も弱い部分
    - 一貫性のない、恣意的な、または気まぐれな分類またはカテゴリー化の決定
        - この状態は、デューケアおよびデューデリジェンスの違反
        - 恣意的・衝動的に判断することは、組織の当面の状況と長期的なニーズの両方を失う
    - 分類され、カテゴリー化されたすべての項目の混乱した、不明瞭な、または不完全なラベリング
        - 多くの場合、セキュリティの機微性に関して誤ってマークされた複数の一連のデータが存在してしまう可能性は非常に高くなる

2-2. 情報と資産の取り扱い要件を確立する

- 分類およびカテゴリーの定義は、防衛請負行者、政府機関、および民間部門の主要なグローバル企業と同様に、中小企業（SME）および中小規模ビジネス（SMB）にも直接適用可能
- NIST SP 800-60 Rev.1、FIPS 199、GDPR、ISO/IEC標準に準拠しているがそれらを利用することに依存しない

データ分類とカテゴリー化のポリシー

- データ分類とカテゴリー化

    - 必要な情報セキュリティ保護のレベルを決定するために使用される基準とプロセスを定義
- データアクセス
    - データにアクセスできるユーザーのロール定義
- データセキュリティ
    - データが一般的に利用可能か、またはデフォルトで制限されているか
- データの保持
    - 自らのデータに関する規制要件を把握し、規制要件とビジネス要件に基づいて保持期間を決定する
- データの廃棄
    - 印刷：クロスカットしゅレッティングなど
- データの暗号化
    - データを暗号化する必要があるかどうか、およびその方法を決定する必要がある
- データの適切な使用
    - データが社内で使用されるか、特定のロールを持つユーザーのみの使用に制限されるのか

分類とカテゴリー化のレベルとラベル

データの機微性レベルとラベル

- 機微性レベルのセット
    - 高度に制限される（Highly restricted）
        - 組織の将来の存在が危険にさらされるレベル
    - 中程度に制限される（Moderately restricted）
        - 一般的な競争優位の喪失、収益の喪失、または計画された投資や活動の中断に繋がる可能性があるレベル
    - 低機微（Low sensitivity）
        - 内部使用のみ（internal use only）と呼ばれることもある
        - 軽微な混乱、遅延、または影響が生じる可能性があるレベル
    - 制限のない公開データ（Unrestricted public data）
        - すでに公開されているデータ

データのカテゴリー化ラベル

- 人間の安全性が重要：生命の損失や負傷
- 設備及び財産の安全性が重要：物理的資産またはシステムが損傷する可能性
- 個人を特定できる情報（PII）が重要：特定の人物を一意に識別できる
- プライベートデータ：引こうか、または制限データ
- 専用データ：組織の内部ロジック・プロセス・意思決定基準
- コンプライアンスデータ：法律、規制、または契約によって要件が定義
- タイムクリティカルデータ：ビジネス・組織活動が失敗、キャンセル、遅延

米国の法律

- Family Education Rights and Privacy Act（FERPA）
    - 1974年に制定され、米国教育省（ED）が管轄する、学生の教育記録のプライバシーを保護する法律です。
- HIPPA
    - 1996年に制定され、米国保健福祉省（HHS）が管轄する、患者の医療・健康情報を厳格に保護する法律です。

2-3. リソースを安全にプロビジョニングする

IT資産管理のライフサイクル

- 管理活動への2つのおおまかなパス（計画的とディスカバリ）
    - 要件主導の計画的プロセス。ある項目が組織の目標や目的と一致しない限り、管理に値する資産ではないことを前提
    - 多くのIT資産が組織がビジネスを行う方法の一部であり、カテゴリー化または分類プロセスを通じて、情報セキュリティのニーズを決定する必要がある
- IT資産管理ライフサイクルの各ステップ
    - 計画立案
        - IT資産の特定
        - 資産の運用ライフサイクルを通じた費用の合計
        - 予想収益
        - 競争優位の合計
        - 損害の合計
    - セキュリティニーズの割り当て
        - 組織または他者が被る可能性のある損害の観点から、資産を分類およびカテゴリー化する
    - 資産の取得
    - 運用用途への配備
    - 配備された資産の管理
        - 継続的なセキュリティアセスメント
            - パフォーマンスとセキュリティの監視
            - 復旧計画と運用
            - バックアップとリストア
    - 資産の廃止
- 計画的モデルとディスカバリーモデルの比較
    - まず、組織が認識しているすべての情報資産のインベントリー、カタログ、またはレジストリーを作成
    - それらが存在しているか
    - ウィッシュリストが存在しているか
    - 作成する・取得する必要があるか

情報資産インベントリー

- 組織の年間予算策定の例
    - 予算計画、レビュー、承認のプロセスは、支出計画の「What-if」スプレットシート図からシュミレーションまで実用的な製品を生み出す
    - この過程で、毎年の予算のインベントリー登録が必要
- 情報資産インベントリーを作成するための鍵は、事業プロセスや組織プロセス、およびそれぞれの優先順位とリスクアセスメントを、そのプロセスに必要とされ、作成され、修正され、出力され、または保持された一連の情報に関連助けること
- 構成管理データベース（CMDB）には、メーカー、モデル、シリアル番号、資産タイプ番号、バージョン番号などの必要な情報が含まれる
    - CMDBは資産のインベントリ～であるだけではなく、組織がなにを持っているか、そしてどのように構成されているかを含む

情報資産の所有権

- 情報資産インベントリーの構築と意地のプロセスの重要な部分は、責任者または組織を資産オーナーとして特定すること

2-4. データライフサイクルを管理する

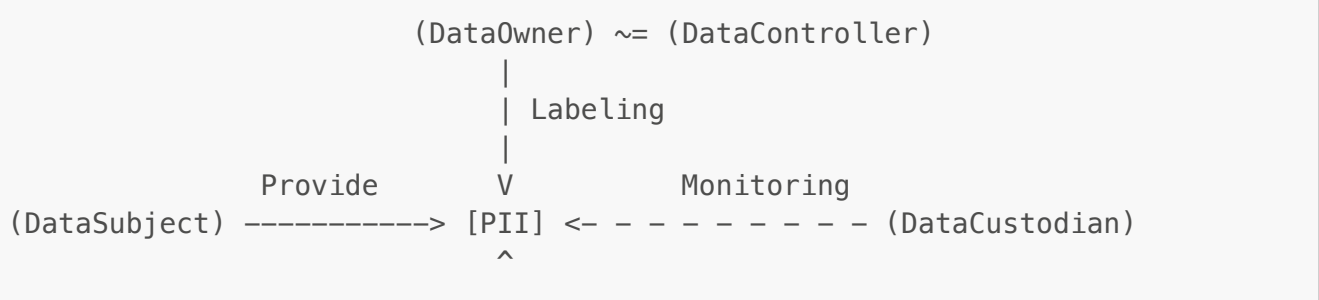
- データが作成されてから破棄されるまでの間に、人や組織が果たすべき役割を確認する

データセキュリティライフサイクル

- すべてのデータ（無形資産）は、作成から破棄までに6つの状態がある
    - 作成（暗黙知）
        - 分類
    - 保存（形式知）
        - 暗号化、アクセス制御、ロギング、監視、冗長性など
    - 利用（追加・修正・閲覧・削除など）
        - データ損失防止（DLP）、デジタル著作権管理（DRM）、アクセス制御など
    - 共有（コピーなど）
        - DLPなどで不正な共有を検知
    - アーカイブ（以降変更されないように保護する）
    - 破棄（利用不可にする）
        - 防御可能な破棄

データロール

- プライバシー法は、個人が自身の個人情報をコントロールできるようにするための法律
- コンプライアンスを遵守するために、組織はアカウンタビリティと責任を適切に割り当てる必要がある
    - それぞれの役割：
        - データサブジェクト : データによって識別される個人。データが参照する個人
        - データコントローラー : 個人データの処理や保護の目的と方法を決める人。
        - データプロセッサー : データを処理する人やプロセス。処理実行者
        - データ保護責任者：データ処理をする組織における、すべてのコンプライアンスについて助言する。政府とのインターフェイスになることも
        - データオーナー : 所有するデータの価値決定と保護を行う人。保護責任者＆権限付与者。管理者とも呼ばれる
        - データスチュワード : データの内容、前後関係、関連業務ルールについて責任を負う人。データ使用の監視者
        - データカストディアン : データが保存されている間の完全性や機密性の責任を負う人。データ監視者。データ管理者とも呼ばれる
            - データオーナーから監視に関する権限を付与される
            - 保護ルールの作成とデータセキュリティの監視を行う



```
                                |          Monitoring
                                | Use <- - - - - - - - (DataSteward)
                                |
                          (DataProcessor)
```

データライフサイクルに関する考慮事項

- データ収集 : 収集したらデータオーナーを任命してデータを分類する
- データロケーションとデータローカライゼーション : データ保存場所、保護の仕組み、保持期間などの現地の法律を理解する
- データメンテナンス : 各フェーズでデータ保護制御の実施を保証する
    - DLPやデジタル著作権管理 (DRM)、暗号化によるアクセス制御など
- データ保持 : 必要な期間のみ保存されるようにする
- データ残留 (Remnant Data) : 通常の使用期間が終了した後も情報を保持しているものに注意する
    - ストレージシステム、CPUのレジスタやRAM、ディスプレイ画面の回路など
    - SSDは「ウェアレベリング」機能によって別の領域にデータのコピーが常に作られるため、従来のサニタイズ手法では効果が得られない場合がある
- データ破棄 : データ残留に対する対策方法
    - サニタイズ : データ破壊に関する広い概念。再利用する前にデータが残らないようにすること。PCから取り外す手順やディスク暗号化も含まれる
    - クリアリング : ランダムな値やゼロで上書きすることでデータ破壊を行うこと
    - パージング : 物理的な影響が残っている可能性を排除する作業のこと。HDDのデガウス (消磁) など
    - 物理破壊 : 媒体の再利用をしない場合の処理。裁断、切断、分解、酸でエッチング、焼却、埋め立て-エンドオブライフとエンドオブサポート : データの使用・保持・移動をサポートするハードウェア・ソフトウェア・サービスが突然サポート切れしたときのデータ損失を考慮する

2-5. 適切な資産保持を確実にする

- エンドオブライフとエンドオブサポート : データの使用・保持・移動をサポートするハードウェア・ソフトウェア・サービスが突然サポート切れしたときのデータ損失を考慮する
- NIST SP 800-30は、廃棄または交換するシステムコンポーネントに対して、リスク管理活動を実施する必要があると規定
    - SWバージョンのEOL期間は、そのSWの開発者がEOL通知を送信した時点で開始
    - EOL通知は、EOL日の役6ヶ月前に行われる必要がある。サポート終了までのタイムラインが含まれるべき
    - 直接交換品が提供される場合には、開発者がEOL期間を短縮する場合がある
        - サポート契約はSWバージョンのEOL日を超えて、延長してはならない

2-6. データセキュリティコントロールとコンプライアンス要件の決定

- データや情報の状態は、以下の3つのいずれかになる：
    - 保存データ : メディアに保存されており、プロセスなどが使用中でないデータ
        - リスク：悪意のあるユーザーがデバイスへの不正な物理または論理アクセスを獲得し、機密性を脅かす
        - 推奨事項：リムーバルメディア及びモバイルデバイスを暗号化する必要がある
    - 移動中(転送中)のデータ : ネットワークを通して移動しているデータ。リンク暗号化やエンドツーエンド暗号化によって保護される

        - リスク：保存中と同じ不正な開示、変更、利用不能が含まれる
        - 推奨事項：保護されたサブネットでも暗号化する必要がある。電子メールは安全と見るな
            - SSL v3.0： 1996年にNetscape社が開発したウェブ通信を暗号化するプロトコルですが、脆弱性のため現在は完全に廃止されています。
            - TLS 1.0： 1999年にIETFがSSL v3.0をベースに策定した次世代の通信暗号化プロトコルですが、同様に現在は非推奨（廃止）です。
            - PGP（Pretty Good Privacy）： 1991年にPhil Zimmermann氏が開発した、ユーザー同士の信頼関係（信頼の網）をベースに電子メールを暗号化・署名する仕組みです。
            - S/MIME（secure/multipurpose internet mail extensions）： 1995年にRSA Data Security社やIETF等が策定した、認証局が発行する電子証明書を用いて電子メールを暗号化・署名する仕組みです。
            - FIPS暗号化アルゴリズム： 2001年（AESのFIPS 197採択時）等に米国国立標準技術研究所（NIST）が認証した、米政府機関でも利用される厳格な基準を満たした暗号化アルゴリズム群です。
            - IPsec： 1995年にIETFが策定した、ネットワーク層（IPレイヤー）で通信を暗号化・認証し、安全なVPNなどを構築するためのプロトコルスイートです。
            - SSH： 1995年にTatu Ylönen氏が開発（のちにIETFで標準化）した、暗号化を用いて遠隔のサーバーへ安全にログインやコマンド実行を行うためのプロトコルです。
        - リンク暗号化： 通信経路のノード（ルーター等）間でデータを暗号化する技術で、データ本体だけでなくルーティング情報（ヘッダー）を含むすべてを保護します。
        - エンドツーエンド暗号化（E2EE）： 送信元から送信先（端末間）までデータを暗号化したまま届ける技術で、通信経路上の第三者やサーバー管理者でも中身を解読できません。
    - 使用中のデータ：追加・修正・削除などの処理やアクセスがされているデータ
        - 推奨事項：「エンクレーブ（Enclave）」とは、セキュリティの分野において、信頼できない環境（OSや他のアプリ）から隔離された、完全に安全で保護されたメモリ領域や実行環境のことです。たとえるなら、泥棒が侵入してくるかもしれない建物（コンピュータ）の中に設置された、「絶対にこじ開けられない最高機密の金庫室」のようなものです。

比較項目	リンク暗号化 🌐	エンドツーエンド暗号化（E2EE） 🔒
復号される場所	**通信経路上の各ノード（ルーターやスイッチなど）**	**最終目的地（受信者の端末）のみ**
暗号化の範囲	**パケット全体**（データ ＋ 宛先等のヘッダー情報）	**データ（ペイロード）部分のみ**（宛先は暗号化しない）
途中のノードでの状態	次の送り先を確認するため、**一度データが復号される**	宛先だけを見て転送するため、**データは暗号化されたまま**
最大のメリット	誰が誰に送ったかという「トラフィック分析」を防げる	途中のサーバーや通信会社がハッキングされても**中身を盗まれない**
主な用途・例	ネットワーク事業者内の通信、衛星通信	LINE、Signal、WhatsApp、iMessageなどのメッセージアプリ

データ損失防止

DLP（Data Loss Prevention：データ損失防止）とは

機密情報や重要なデータが、外部に**漏洩・紛失するのを防ぐためのセキュリティシステムや一連の対策**のことです。

DLPの3つのコンポーネント

1. ディスカバリと分類（Discovery & Classification）

- **概要**: 社内のネットワーク、サーバー、クラウド、PC等の中に**「どこに」「どのような」機密情報があるかを探し出し（ディスカバリ）、重要度に応じてラベルを貼る（分類）**プロセスです。
- **役割**: 保護すべき対象（個人情報、クレジットカード番号、機密ソースコードなど）を正確に把握するための、DLPのすべての土台となるステップです。

2. 監視（Monitoring）

- **概要**: 分類された機密情報が、日常業務の中で**「誰によって」「どのように使われているか」をリアルタイムでチェックする**プロセスです。
- **役割**: データの動き（USBへのコピー、メール添付、クラウドへのアップロードなど）を常に監視し、不審な移動や不正な持ち出しの兆候を検知します。

3. 執行（Enforcement）

- **概要**: 監視によってあらかじめ設定した**ポリシー（ルール）に違反するデータの動きを検知した際、システムが自動的にブロックや処置を行う**プロセスです。
- **役割**: 「機密ファイルの送信を遮断する」「ファイルを自動的に暗号化する」「管理者に警告を通知する」といった具体的な防御アクションを起こし、実際の漏洩を未然に防ぎます。

DLPアーキテクチャの解説：DIM・DAR・DIU

- DLP（データ損失防止）アーキテクチャは、データが置かれている**「3つの状態」**に合わせてセキュリティを配置し、漏洩を包括的に防ぎます。データは業務のなかで流動的に状態を変える（保存 ⇄ 移動 ⇄ 利用）ため、DLP製品はこの3つのアーキテクチャを組み合わせて機能します。

1. DIM（Data in Motion：移動中のデータ）

- **概要**: 組織のネットワーク内、あるいは外部（インターネット・クラウド）に向けて**通信経路を移動しているデータ**を保護します。
- **主な配置ポイント**: ネットワークの境界（Webプロキシ、次世代ファイアウォール、メールゲートウェイ、CASBなど）
- **監視・制御の例**:
  - 社員がクレジットカード番号の含まれたファイルを個人用クラウド（Google ドライブ等）へアップロードしようとした際に検知・ブロックする。
  - 機密マーク（分類ラベル）のついたファイルを外部メールに添付して送信するのを遮断する。
- **特徴**: データを外へ「出さない」ための水際対策であり、暗号化通信（HTTPSなど）を一度復号して中身を検査する**SSLインスペクション**技術と深く連携します。

2. DAR（Data at Rest：保存中のデータ）

- **概要**: サーバー、データベース、クラウドストレージ、個人のパソコンのハードディスクなど、**どこかに「保管・蓄積されている」データ**を保護します。

- **主な配置ポイント**: ファイルサーバー、データベース、SaaSリポジトリ（SharePoint、Boxなど）、ストレージバケット（AWS S3など）
- **監視・制御の例**:
    - 定期的な「ディスカバリ（スキャン）」を実行し、暗号化されていない状態で放置されているマイナンバーを含むファイルを自動検出する。
    - ポリシーに違反して共有設定が「全員に公開」になっている機密ファイルを検知し、自動的に閲覧権限を修正（隔離）する。
- **特徴**: データの全容を把握する「ディスカバリと分類」に最も貢献するレイヤーであり、強力な暗号化（AES-256等）やアクセス制御と組み合わせて運用されます。

3. DIU（Data in Use：利用中のデータ）

- **概要**: ユーザーがアプリケーションを開いて編集している最中や、メモリ上に展開されて**まさに「現在アクティブに処理されている」データ**を保護します。
- **主な配置ポイント**: ユーザーが操作するPCやモバイル端末（エンドポイント）に導入された**DLPエージェント（常駐ソフト）**
- **監視・制御の例**:
    - 画面上の顧客データを「コピー」して、個人のチャットツールに「貼り付け」する操作を禁止する。
    - 社外秘のドキュメントを印刷（プリントアウト）したり、USBメモリにエクスポートしたりする操作をブロックする。
    - 機密ドキュメントのスクリーンショット撮影を制限する。
- **特徴**: ユーザーがネットワークを介さないオフライン状態（自宅でインターネットを切断して作業している場合など）であっても、端末側で直接ユーザーの挙動を監視・コントロールできる点が強みです。

クラウドアクセスセキュリティブローカー

- クラウドアクセスセキュリティブローカー（CASB）とは
    - **クラウドアクセスセキュリティブローカー（CASB：キャスビー）**とは、企業・組織のユーザーと複数のクラウドサービス（SaaS/PaaS/IaaS）の間に立ち、**すべてのやり取りを一元的に監視・制御するセキュリティチェックポイント（中継システム）**のことです。
    - ガートナー（Gartner）社によって提唱された概念で、社員が利用するクラウドサービスの安全性やデータの動きを可視化し、セキュリティポリシーを適用する役割を持っています。

データセキュリティベースラインの確立

- セキュリティベースラインは、基準となる最低限のセキュリティ

ベースライン保護の目的

- 組織の分類した資産を保護するために、最低限のセキュリティ対策を確立すること

ベースラインカタログ

- ベースラインは、セキュリティ構成の集合
    - 組織のセキュリティ要件に合致するように調整できる
- ベールラインカタログは、使用すべきセキュリティ対策や、取り組むべきセキュリティ要件を提案している

1. United States Government Configuration Baseline (USGCB)

- **管轄**: 米国政府（主に米国国立標準技術研究所：NISTが中心となり推進）
- **概要**: 連邦政府機関で広く導入されている**IT製品（OSやブラウザなど）の安全な構成設定（コンフィギュレーション）の統一基準**です。
- **主な特徴**:
    - **旧FDCCからの進化**: 前身である「FDCC（連邦デスクトップ基本構成）」の義務化から発展し、セキュリティ設定を維持・向上させる目的で策定されました。
    - **具体的な製品への適用**: WindowsやInternet Explorer、Red Hat Enterprise Linux（RHEL）などの個別製品を対象に、ハッカーに悪用されやすい設定（不要なサービスの有効化など）をあらかじめ排除した「政府公認の安全な標準設定マニュアル」を提供します。
    - 組織内のPCやサーバーの「設定のブレ（ドリフト）」を防ぎ、全政府機関のセキュリティレベルの底上げに大きく貢献しました。

2. IT Baseline Security System ISKE

- **管轄**: エストニア情報システム局（RIA：Information System Authority）
- **概要**: エストニアの公的機関や自治体のデータベースにおいて、**国家機密以外のデータを保護するために適用されていた「3段階のITセキュリティ・ベースラインシステム」**です。
- **主な特徴**:
    - **ドイツの基準がベース**: ドイツの有名なセキュリティ基準「BSI IT-Grundschutz」を土台に、エストニア独自の国民IDカードシステムやデータ連携基盤「X-Road」に対応する要素を加えて2003〜2004年頃に構築されました。
    - **リスクに応じた3階層**: 一律に対策を強制するのではなく、システムの重要度やリスクに応じて「高（H）」「中（M）」「低（L）」の3つのセキュリティレベルに分類し、組織的・物理的・技術的な対策を提示していました。
    - 🚨 **現在の状況**: ISKEの法的根拠は**2023年末に失効（終了）**しています。国際標準のISO/IEC 27001と整合性を高めた、新しいエストニア独自の情報セキュリティ標準**「E-ITS（Estonian Information Security Standard）」**へと完全に移行されました。

💡 両者のアプローチの違い

- **USGCB**は、「OSやソフトウェアの**具体的なパラメータや設定値をどう固定するか**」という技術的な構成ベースラインに特化しています。
- **ISKE**（および後継のE-ITS）は、「システムのリスクに応じて、**組織全体としてどのような物理的・技術的セキュリティ対策のセットを網羅すべきか**」という包括的なフレームワーク（制度）を提供しています。

一般に認められた原則

- 情報セキュリティを俯瞰できる一般的な原則がいくつかある：
- 予防、検知、対応、復旧
    - これらの組み合わせ、CIAの期待される状態への復旧
- 使用中、転送中、保存中の情報の保護
    - CIA維持
- 外部システムをセキュアではないと見なすこと
- 情報システムのレジリエンス（破壊的な出来事に耐え得ること）
- 監査能力とアカウンタビリティ
- その他いろいろ
    - 範囲の決定とテーラリング

    - フレームワークやスタンダードを導入する際は、範囲を決定する（スコーピング）
        - スコーピングは、ベースラインのコントロールを保護対象のシステムに適用させるときに行う
    - テーラリングを通して、組織はフレームワークやスタンダードの一部分だけを導入することもできる
        - テーラリングは、手順などを組織に適したものに調整すること

情報分類と情報カテゴリー化の比較（サイバーセキュリティ）

📌 コア概念の違い

- **情報分類（Classification）**
    - **データ単体**の「機密性（漏洩リスク）」に着目する。
    - 資産の価値、秘密度に応じてラベル（極秘・秘密など）を付与する。
- **情報カテゴリー化（Categorization）**
    - **システム全体**の「CIA（機密性・完全性・可用性）への影響度」に着目する。
    - 組織や業務に与えるインパクトの大きさ（高・中・低）を評価する。

📊 対比表

評価軸	情報分類 (Classification)	情報カテゴリー化 (Categorization)
主な評価対象	**データ、ファイル、文書**	**情報システム、システム内の情報タイプ**
主な基準	**機密性（Confidentiality）** のみ	**機密性・完全性・可用性（C-I-A）** のすべて
決定する要素	個別の**アクセス権限、暗号化の有無**	システム全体の**セキュリティベースライン（対策基準）**
基準となる規格	ISO/IEC 27001、GDPR 等	FIPS 199、NIST SP 800-60 等
分類の例	公開、社内限り、秘密、極秘	高（High）、中（Moderate）、低（Low）

🛠️ 実務における相互関係

1. **ステップ1：カテゴリー化（土台決定）**
    - システムが停止・改ざん・漏洩した際の影響度を「高・中・低」で評価し、そのシステム全体に必要な**セキュリティ対策（ベースライン）**を決定する。
2. **ステップ2：分類（個別制御）**
    - そのシステム内部で流通するデータに対して「極秘・秘密」などのラベルを貼り、具体的な**アクセス制御（DLP、閲覧権限）**を個別に適用する。

情報資産の分類と具体例

情報セキュリティマネジメント（ISMS等）において、情報資産を「ハードウェア」「ソフトウェア」「情報」「ファームウェア」に分類した際の具体例を記述したマークダウンコードです。

💻 1. ハードウェア（物理的資産）

情報を処理・保存・伝達するための物理的な機器や設備。

- **クライアント機器：** 社用PC（デスクトップ/ノート）、スマートフォン、タブレット
- **インフラ・サーバ機器：** 社内サーバ（ファイルサーバ、認証サーバ）、NAS、ラック、無停電電源装置（UPS）
- **ネットワーク機器：** ルータ、スイッチングハブ、Wi-Fiアクセスポイント、ファイアウォール（専用アプライアンス）
- **周辺機器・記憶媒体：** 複合機/プリンタ、外付けHDD/SSD、USBメモリ、ICカードリーダー

💿 2. ソフトウェア（論理的資産）

ハードウェア上で動作し、データを処理・制御するプログラムやライセンス。

- **オペレーティングシステム（OS）：** Windows、macOS、Linux、iOS、Android
- **業務用アプリケーション：** 会計ソフト、人事管理システム、CRM/SFA（顧客管理）、CADソフト
- **事務用・共通ツール：** Microsoft 365（Word, Excel等）、Slack/Zoom（コミュニケーションツール）
- **セキュリティ・開発ソフト：** ウイルス対策ソフト、統合開発環境（IDE）、データベース管理システム（DBMS）
- **自社開発システム：** 独自開発した基幹システム、ECサイトのソースコード

📄 3. 情報（データ・コンテンツ資産）

組織が業務上保有・利用するデジタルデータ、および紙媒体の記録。

- **電子データ（デジタル）：**
  - **顧客・個人情報：** 顧客名簿、クレジットカード情報、社員のマイナンバーデータ
  - **財務・経営情報：** 未公開の決算データ、M&A計画書、役員会の議事録
  - **技術・知的財産：** 製品の設計図、特許出願前の研究データ、ノウハウ
- **紙媒体（アナログ）：** 契約書原本、顧客からの申込書、手書きの議事録、重要書類のコピー
- **システム関連文書：** システム仕様書、ネットワーク構成図、運用マニュアル、利用規約

⚙️ 4. ファームウェア（組み込み資産）

ハードウェアに内蔵され、その機器を動作させるための専用ソフトウェア。ハードウェアとソフトウェアの中間に位置する。

- **PC・サーバ用：** BIOS / UEFI（PC起動時にハードウェアを制御する基本プログラム）
- **ネットワーク機器用：** ルータやWi-Fiアクセスポイントの内部制御OS（パッチ適用や脆弱性管理の対象）
- **周辺機器用：** 複合機（プリンタ）の制御プログラム、SSD/HDDのコントローラ用ファームウェア
- **その他セキュリティ機器用：** UTM（統合脅威管理）やハードウェアトークンの内部プログラム

データのサニタイズ（初期化・処分）における4つのレベルと具体例

サイバーセキュリティの基準（米国の **NIST SP 800-88 Rev.1「媒体サニタイズに関するガイドライン」** など）において、データの消去や処分は機密性（保護レベル）に応じて4つの段階に分類されます。

「再フォーマット」「クリアリング」「パージ」「破壊」の順に、データの復元が困難（レベルが強力）になります。

📊 サニタイズレベルの比較一覧

レベル	処分の定義	復元可能性の度合い	主な対象シーン
1. 再フォーマット (Reformat)	OSの標準機能による初期化	**容易に復元可能** (市販の復元ソフトで戻せる)	同一ユーザー内での再利用、単なる整理
2. クリアリング (Clear)	標準的な読み書き機能を用いた上書き	**実験室レベルで復元不可能** (一般的なツールでは復元不可)	社内（組織内）での別部署・別ユーザーへの転用
3. パージ (Purge)	技術的な手法を用いた完全なデータ除去	**最新の解析環境でも復元不可能** (国家レベルの技術でも復元不可)	組織外への売却、PCのリース返却、ベンダーへの譲渡
4. 破壊 (Destroy)	物理的なサニタイズ（媒体の物理的滅失）	**物理的に復元不可能** (媒体自体が消滅)	故障した機器の廃棄、最高機密（極秘）データの最終処分

🔍 各レベルの詳細と具体例

1. 再フォーマット（Reformat）※NIST基準未満

OS（WindowsやmacOSなど）に標準搭載されている「フォーマット（クイックフォーマット）」や「ゴミ箱を空にする」操作です。

- **仕組み：** データの「管理領域（目次）」だけを消去し、データ本体の領域は「上書き可能」な状態にするだけです。データ本体はそのまま残っています。
- **具体例：**
  - WindowsでUSBメモリを右クリックして「フォーマット」を実行する。
  - スマホを売る前に設定から「すべてのコンテンツと設定を消去」する（旧世代の暗号化されていない端末の場合）。

2. クリアリング（Clear）

データが書き込まれているすべての領域に対して、別のデータ（「0」や固定値、ランダムな値）を上書きし、一般的なデータ復元ツールでは読み取れない状態にする処理です。

- **仕組み：** OSのデータアクセス機能を利用して、媒体の全セクタに固定パターンやランダムな値を1〜数回上書き（ゼロフィルなど）します。
- **具体例：**
  - Windowsの「通常のフォーマット（クイックではない）」を実行し、全領域に0を書き込む。
  - データ消去専用ソフト（Blanccoなど）を使い、1回上書き（ゼロ書き込み）を実行する。

3. パージ（Purge）

高度な技術（実験室レベルのデータ復元技術）を持った攻撃者が相手でも、一切データを復元できないようにする強力なデータ除去プロセスです。

- **仕組み：** 磁気媒体（HDD）であれば強力な磁気を照射して磁気配列をランダム化（消磁）します。フラッシュメモリ（SSD）であれば、コントローラに内蔵された専用コマンド（Secure Erase / Cryptographic Erase）を発行し、内部の電圧を一斉にリセット、または暗号化キーを即座に破棄して瞬時にデータを解読不能にします。
- **具体例：**
  - 専用の強磁気消磁装置（デガウザー）にHDDを投入し、磁気記録を完全に破壊する。
  - SSDに対して、NVMe Cryptographic Erase（暗号化消去）コマンドを実行し、データの復号鍵を物理的に消去する。

4. 破壊（Destroy）

物理的な力や化学変化、熱を利用して、記憶媒体そのものを再利用不可能な形に変形・滅失させる最も確実な最終処分方法です。

- **仕組み：** 媒体を物理的に細断、粉砕、焼却、または融解させます。
- **具体例：**
  - 物理クラッシャー（穴あけ機）を使い、HDDのプラッタ（磁気ディスク）に複数の穴を開ける。
  - 記憶媒体（SSDのフラッシュメモリチップなど）を、専用のシュレッダーで数ミリ単位の微粒子に粉砕（物理細断）する。
  - 専門の処分業者に委託し、溶解炉で跡形もなくドロドロに溶かす（溶融処理）。

セキュリティ影響度レベル（高・中・低）に応じたベースライン要求要件

情報カテゴリー化（FIPS 199 / NIST SP 800-60）によって決定された**「高（High）」「中（Moderate）」「低（Low）」**の影響度レベルに応じて、システムに要求されるセキュリティベースライン（具体的な対策の強度）は以下のように変化します。

ご提示いただいた具体的なコントロール（パスワード、暗号化、ウォーターマーク、リアルタイム監視）をベースに、要求水準の違いをマークダウンコードで記述します。

📊 セキュリティベースライン要求要件の比較表

対策項目	低影響度 (Low)	中影響度 (Moderate)	高影響度 (High)
認証とパスワード	・標準的なパスワード認証 ・最低限の複雑性ルール	・**多要素認証（MFA）**の必須化 ・厳格な複雑性と定期変更	・**フィッシング耐性のあるMFA** ・ハードウェアトークンの推奨

対策項目	低影響度 (Low)	中影響度 (Moderate)	高影響度 (High)
暗号化（データ保護）	・重要データのみ暗号化 ・標準的な暗号アルゴリズム	**・保存時・通信時の全面暗号化** ・FIPS 140準拠の鍵管理	**・超強力な暗号（AES-256以上）** ・HSM（専用機器）による鍵管理
ウォーターマーク (電子透かし・DLP)	・対策なし（または任意）	・機密文書への自動付与 ・ラベルに基づくアクセス制御	**・動的・非可視ウォーターマーク** ・透かしによるDLP完全連動
監視（モニタリング）	・定期的なログ確認 ・数日〜週次の監査確認	**・リアルタイムのログ集中管理** ・時間外アクセス等の異常検知	**・24時間365日の連続監視（SIEM/SOC）** ・AIによる振る舞い検知・即時遮断

🔍 各レベルにおける具体的な対処法と要件

1. 低影響度レベル（Low Baseline）

システムが侵害されても、組織の業務停止やプライバシー漏洩による損害が「軽微」で済むシステム向けのベースラインです。

- **認証・パスワード：** 単一の要素（IDとパスワード）でも、最低8文字以上、英数字混合などの標準的なルールを満たしていれば許容されるケースがあります。
- **暗号化：** パスワードのハッシュ化や、ログイン画面の通信（HTTPS）など、最低限必要な箇所のみ暗号化します。
- **ウォーターマーク：** 要求されません。
- **リアルタイム監視：** リアルタイムである必要はなく、週に1回、あるいはインシデント発生後にログを追える状態（ログの常時記録）になっていればベースラインを満たします。

2. 中影響度レベル（Moderate Baseline）

システムが侵害されると、組織の業務に深刻な停滞が発生したり、重大なプライバシー漏洩（一般的な個人情報など）につながる大半の商用・社内システム向けのベースラインです。

- **認証・パスワード：** **多要素認証（MFA）が必須**となります。パスワードのみでの管理者ログインや外部からのアクセスは禁止されます。
- **暗号化：** 通信中のデータ（データ・イン・トランジット）だけでなく、ハードディスクやデータベースに保存されているデータ（データ・アット・レスト）の**全面暗号化**が要求されます。
- **ウォーターマーク：** データの機密分類（分類ラベル）と連動し、画面キャプチャやPDF出力時に「社外秘」などのウォーターマーク（電子透かし）をシステムが自動で挿入する仕組みが求められます。
- **リアルタイム監視：** 各種ログをSIEM（ログ統合管理システム）に集約し、管理者以外のアカウントが深夜に大量のデータをダウンロードするなどの「異常な挙動」を**リアルタイムに検知・アラート通知**するベースラインが要求されます。

3. 高影響度レベル（High Baseline）

システムが侵害された場合、組織の存続危機、国家安全保障への脅威、あるいは人命に関わる致命的な損害（インフラ、医療、最高機密データ等）が発生するシステム向けのベースラインです。

- **認証・パスワード：** 通常のMFAでは不十分とされ、認証情報の横取りを防ぐ**「フィッシング耐性のある多要素認証（FIDO2/WebAuthnやICカードなど）」**の導入が義務付けられます。
- **暗号化：** AES-256などの最高強度の暗号化が必須であり、暗号鍵の管理には物理的な専用安全装置（HSM：ハードウェア・セキュリティ・モジュール）の使用が求められます。
- **ウォーターマーク：** 単に文字を表示するだけでなく、誰がいつ出力したかを追跡できる「動的ウォーターマーク」や、画像データに埋め込む「非可視（電子）スナップショット」が要求されます。万が一データがカメラで撮影されて流出した場合でも、流出元を特定できるようにします。
- **リアルタイム監視：** **SOC（セキュリティオペレーションセンター）等による、24時間365日の完全連続監視がベースラインとなります。脅威を検知した場合は、人間の判断を待たずにAIやSOAR（自動応答仕組み）によって該当アカウントや通信を自動で即時遮断する機構**まで要求されます。